

Prova S.I.

Total de pontos 60/60

O e-mail do participante (**matheus.santos400@al.unieduk.com.br**) foi registrado durante o envio deste formulário.

- ✓ 1 - No panorama atual de ameaças delineado para 2026, o perímetro de segurança tradicional desapareceu por completo. Firewalls legados baseados em segmentação por zonas geográficas enfrentam sérias limitações na mitigação de riscos internos. *4/4

Considerando a transição do perímetro tradicional para o ecossistema *Zero Trust Architecture*, a decisão de acesso passa a basear-se estritamente em qual princípio?

- ☐ A) Confiança implícita em todo o tráfego originado a partir de dispositivos localizados dentro da rede física.
- ☒ B) Privilégio mínimo baseado estritamente na validação contínua da identidade e no contexto seguro do dispositivo, ignorando a localização física. ✓
- ☐ C) Permissão irrestrita intrazona para servidores que apresentem certificações SSL/TLS legadas válidas.
- ☐ D) Desativação de inspeções profundas de pacotes na borda para otimizar o desempenho do hardware local.
- ☐ E) Delegação completa da governança de acessos lógicos à infraestrutura física do provedor de nuvem.



- ✓ A engenharia de ransomwares atingiu um patamar corporativo. 4/4
Campanhas caóticas e de alto ruído do passado deram lugar à chamada "Extorsão Industrializada".

Qual é o objetivo operacional primário e a estratégia de pressão central adotada por grupos cibercriminosos avançados em 2026?

- ☐ A) Destruição massiva de hardware local por meio de sobrecarga elétrica controlada via software.
- ☒ B) Extorsão focada primordialmente na exfiltração de dados sensíveis para alavancar pressão reputacional, de acionistas e regulatória. ✓
- ☐ C) Dependência exclusiva de chaves de criptografia simétrica rudimentar transmitidas via disquetes ou suportes físicos offline.
- ☐ D) Paralisação temporária de roteadores sem a cópia ou extração de ativos confidenciais da organização.
- ☐ E) Envio automatizado de pedidos de resgate diretamente para caixas postais físicas de representantes legais.



- ✓ As métricas de monitoramento de redes apontam que o tráfego interno, conhecido como Leste-Oeste, ultrapassou consideravelmente o tráfego Norte-Sul em volume e importância analítica crítica dentro dos data centers modernos. 4/4

Qual desafio técnico complexo faz com que o tráfego Leste-Oeste seja o esconderijo ideal para a movimentação lateral invisível de malwares e como ele deve ser mitigado?

- ☐ A) O tráfego opera em texto claro; a mitigação consiste em desativar firewalls comportamentais de borda.
- ☒ B) Cerca de 90% do tráfego corporativo interno corre criptografado por TLS; a mitigação exige pipelines de Deep Observability para extração de metadados e avaliação em tempo real. ✓
- ☐ C) O tráfego é inteiramente composto por requisições HTTP inválidas; a mitigação envolve o uso de LocalStorage no cliente.
- ☐ D) A ausência de largura de banda suficiente; a mitigação é resolvida substituindo conexões de fibra por hardware NGFW analógico.
- ☐ E) O tráfego Leste-Oeste toca o perímetro externo continuamente; a mitigação foca em rotinas manuais de patches de segurança.



- ✓ O avanço das arquiteturas de nuvem dividiu as camadas de proteção. O Provedor de Serviços de Nuvem (CSP) responsabiliza-se estritamente pela segurança DA nuvem, restando ao cliente a gestão interna. 4/4

Sob a perspectiva do modelo de responsabilidade compartilhada na nuvem, qual ativo permanece sob a responsabilidade inalienável da empresa cliente nos modelos IaaS, PaaS e SaaS?

- ☒ A) A governança, o controle de acesso e a segurança integral dos dados confidenciais inseridos na plataforma. ✓
- ☐ B) O ciclo de manutenção de hardware, switches e fontes elétricas de redundância do data center físico.
- ☐ C) A aplicação de atualizações críticas de firmware nos hypervisors do provedor.
- ☐ D) A infraestrutura de refrigeração e o isolamento físico dos racks de processamento.
- ☐ E) A integridade lógica dos cabos submarinos condutores de dados globais.



- ✓ O conceito de Privacy by Design estabelece que a proteção à privacidade dos titulares deve ser incorporada de forma nativa e proativa em todo o ciclo de vida de desenvolvimento de produtos. 4/4

O princípio da "Configuração Padrão" (Secure by Default) determina que o desenvolvedor deve estruturar a aplicação de forma a:

- ☐ A) Desativar todos os mecanismos de segurança nativos para facilitar a navegação do utilizador na primeira sessão.
- ☒ B) Garantir que as opções que salvaguardam ao máximo a privacidade e a segurança dos dados estejam ativadas automaticamente de fábrica, sem intervenção do utilizador. ✓
- ☐ C) Transferir para planilhas e e-mails isolados do setor de marketing a gestão reativa de consentimentos obtidos.
- ☐ D) Ocultar as opções de privacidade do utilizador para assegurar a monetização de dados sem restrições.
- ☐ E) Permitir a coleta massiva e indiscriminada de dados pessoais antes da aceitação explícita dos termos do portal.



- ✓ Estatísticas globais de inteligência em cibersegurança indicam que uma fração expressiva dos incidentes críticos de vazamento não se origina de técnicas externas de força bruta, mas sim de falhas operacionais internas. 4/4

No contexto da anatomia das ameaças digitais, qual fator representa uma vulnerabilidade crítica severa e recorrente em ambientes computacionais corporativos?

- ☒ A) O erro operacional humano direto e as configurações incorretas ou deficientes em ativos expostos em nuvem. ✓
- ☐ B) A adoção prematura e rigorosa de algoritmos criptográficos assimétricos imunes à computação quântica.
- ☐ C) A implementação de políticas uniformes de segurança gerenciadas centralizadamente por gateways em nuvem.
- ☐ D) O armazenamento isolado de tokens em variáveis voláteis de memória RAM no frontend do cliente.
- ☐ E) A execução sistemática de auditorias regulares baseadas na Resolução No. 04 CD/ANPD.



- ✓ O Artigo 48 da Lei Geral de Proteção de Dados (LGPD) dita o protocolo inegociável de transparência diante de qualquer violação confirmada que possa acarretar risco relevante aos titulares. 4/4

Em caso de crise cibernética, qual ação corporativa constitui uma grave infração regulatória agravada, transformando um problema de engenharia em uma desconformidade jurídica passível de sanções máximas?

- ☐ A) Executar imediatamente um Plano de Resposta a Incidentes (IRP) estruturado e testado pré-crise.
- ☐ B) Isolar equipamentos comprometidos da rede interna antes de remover o artefato malicioso.
- ☐ C) Efetuar a notificação oficial detalhada à ANPD e aos cidadãos envolvidos expondo a natureza do vazamento e o escopo técnico.
- ☒ D) Ocultar deliberadamente o incidente de segurança das autoridades e do público-alvo na tentativa de abafar os impactos midiáticos. ✓
- ☐ E) Utilizar backups íntegros e imutáveis para reestabelecer os serviços da operação.

- ✓ JSON Web Tokens (JWT) são amplamente empregados para estabelecer autenticação portátil e desacoplada em arquiteturas distribuídas e ecossistemas modernos de microsserviços. 4/4

Conforme especificado na RFC 7519, a estrutura padrão de um JWT é composta por três componentes distintos, separados linearmente por pontos. Quais são essas partes, na ordem exata de processamento?

- ☐ A) Cryptographic Hash, Claims Body e Expiration Token.
- ☒ B) Header (Cabeçalho), Payload (Corpo/Claims) e Signature (Assinatura). ✓
- ☐ C) Access Token, Refresh Token e LocalStorage Key.
- ☐ D) Identity Provider Metadata, JSON String e Private Secret.
- ☐ E) Algorithm Type, Base64 String e HTTP Authorization Bear



- ✓ Um equívoco clássico na engenharia de software confunde a finalidade 4/4
criptográfica de um token assinado com a de um token encriptado.

Em relação à visibilidade dos dados transitados em um JWT padrão (não encriptado), assinale a afirmação verdadeira:

- ☐ A) O token oculta nativamente todo o payload, impedindo qualquer leitura visual sem o conhecimento prévio da chave simétrica.
- ☒ B) O conteúdo do Payload é apenas codificado em Base64URL e assinado, o que significa que qualquer pessoa em posse da string pode decodificá-lo e ler livremente suas claims. ✓
- ☐ C) A assinatura digital impede que navegadores e proxies web façam o trânsito seguro do cabeçalho via HTTP Headers.
- ☐ D) É altamente seguro e recomendado embutir senhas de acesso e dados pessoais altamente sensíveis (PII) dentro do payload de qualquer JWT.
- ☐ E) A assinatura garante a ocultação absoluta dos dados de identificação do utilizador por meio de funções reversíveis de ofuscamento.

- ✓ O armazenamento inseguro no frontend expõe tokens digitais a riscos 4/4
severos de exfiltração por meio de injeções de códigos maliciosos na página do cliente.

Qual vulnerabilidade crítica do lado do cliente é efetivamente mitigada ao armazenar um token sensível em um Cookie HTTP configurado com a flag *HttpOnly* ativada, em vez de salvá-lo no *LocalStorage*?

- ☐ A) SQL Injection (SQLi) direcionado ao servidor de banco de dados.
- ☒ B) Cross-Site Scripting (XSS), pois a flag instrui o browser a bloquear o acesso ao cookie via scripts executados em JavaScript (ex: document.cookie). ✓
- ☐ C) Falsificação de Solicitação Entre Sites (Cross-Site Request Forgery - CSRF).
- ☐ D) Ataques de força bruta contra as APIs expostas pelo Identity Provider.
- ☐ E) Engenharia social do tipo Phishing direcionada à equipe de desenvolvimento.
- ☐ Opção 6



- ✓ Bibliotecas desatualizadas de interpretação de JWT implementaram incorretamente a validação do campo do algoritmo criptográfico, permitindo que atacantes manipulassem o fluxo básico de validação.

4/4

Como se operacionaliza o exploit clássico do algoritmo "none" no cabeçalho do JWT e qual a sua mitigação recomendada?

- ☐ A) O atacante descobre o segredo simétrico; mitigação consiste em trocar para hashes md5.
- ☒ B) O atacante altera claims no payload, altera o cabeçalho para "alg": "none" e remove a assinatura; o servidor desatualizado aceita o token manipulado. Mitigação: rejeitar explicitamente o algoritmo 'none' e definir uma lista restrita (whitelist) de algoritmos aceitos. ✓
- ☐ C) O token deixa de funcionar na internet; mitigação envolve salvar o JWT exclusivamente no LocalStorage do frontend.
- ☐ D) O atacante intercepta as chaves públicas do JWKS; mitigação exige o uso obrigatório de HS256 em microsserviços.
- ☐ E) O servidor gera loops infinitos de verificação; mitigação consiste em remover a claim de expiração (exp).



- ✓ Em sistemas distribuídos de microsserviços altamente escaláveis, a arquitetura de chaves criptográficas dita o nível de acoplamento e os impactos em caso de comprometimento local de um nó. 4/4

Qual é a principal vantagem operacional e de isolamento de risco ao optar por assinaturas assimétricas (como RS256) em vez de assinaturas simétricas (como HS256) na validação de JWTs?

- ☐ A) O algoritmo assimétrico processa o triplo de operações matemáticas por segundo comparado ao simétrico.
- ☒ B) Permite uma arquitetura trustless ideal: apenas o Identity Provider possui a Chave Privada para criar tokens, enquanto os microsserviços de backend usam apenas a Chave Pública para verificação. Se um microsserviço for invadido, o atacante jamais conseguirá forjar tokens legítimos. ✓
- ☐ C) Elimina por completo o processamento de cabeçalhos e payloads pelas APIs consumidoras.
- ☐ D) Criptografa as informações confidenciais de forma a impedir ataques baseados em engenharia social.
- ☐ E) Dispensa por completo o uso de HTTPS e certificados digitais nas conexões Norte-Sul de borda.



- ✓ A profissionalização do ecossistema de ameaças digitais gerou nichos de especialização entre agentes cibercriminosos, o que contribuiu para baratear e massificar o modelo criminoso corporativo. 4/4

No contexto da anatomia do ransomware moderno exposto para 2026, qual papel desempenham os intermediários denominados *Initial Access Brokers* (IABs)?

- ☐ A) São responsáveis pelo desenvolvimento de algoritmos de decodificação simétrica para reestabelecer backups travados.
- ☐ B) Atuam como auditores de segurança terceirizados encarregados de emitir relatórios de conformidade com a LGPD.
- ☒ C) São agentes que vendem acesso corporativo pré-comprometido e autenticado na dark web, reduzindo drasticamente as barreiras de entrada para grupos invasores. ✓
- ☐ D) Criam campanhas automatizadas de capacitação contra phishing direcionadas a colaboradores.
- ☐ E) Gerenciam endpoints públicos lógicos para rotação de chaves sem downtime através de endpoints JWKS.
- ☐ Opção 6



- ✓ A arquitetura de Token Duplo constitui uma estratégia consolidada para conciliar a segurança corporativa contra sequestros de sessão com a conveniência de manter o utilizador autenticado por longos períodos. 4/4

Em relação às propriedades e ciclo de vida de cada token nesse arranjo moderno, assinale a opção com a especificação arquitetural correta:

- ☐ A) O Access Token possui ciclo longo (semanas) e o Refresh Token possui ciclo efêmero (minutos), ambos armazenados no LocalStorage global.
- ☒ B) O Access Token apresenta ciclo de vida curto e efêmero (~15 minutos) mantido em memória para mitigar o raio de dano caso seja roubado, enquanto o Refresh Token possui ciclo longo (dias/semanas) e deve ser guardado exclusivamente em cookies HttpOnly, Secure e SameSite. ✓
- ☐ C) Ambos os tokens operam com tempo de expiração desativado para eliminar requisições extras às APIs de backend.
- ☐ D) O Refresh Token transita explicitamente acoplado em Headers lógicos de Authorization a cada requisição de endpoint da API.
- ☐ E) O Access Token atua renovando silenciosamente as credenciais do Refresh Token diretamente no banco de dados de sessões do IdP.



- ✓ A validação rigorosa de credenciais sem estado em ambientes de backend modernos segue premissas matemáticas e lógicas estritas antes de liberar o processamento das rotinas de negócio solicitadas. 4/4

No contexto da engenharia de segurança de software, qual é a distinção teórica crítica e a Regra de Ouro entre os conceitos de "Verificação" e "Validação" de um JWT?

- ☐ A) Verificação checa as regras de negócio como expiração e emissor, enquanto Validação avalia unicamente o hash da assinatura criptográfica.
- ☐ B) Verificação é efetuada no frontend via JavaScript e Validação corre exclusivamente no banco de dados relacional.
- ☒ C) A Verificação valida a integridade matemática da assinatura e atesta que o token não foi adulterado, ao passo que a Validação analisa as claims de negócio (exp, iss, aud). A Regra de Ouro manda nunca validar as regras de negócio antes de verificar a matemática. ✓
- ☐ D) A Verificação descriptografa o cabeçalho e a Validação reescreve a string em Base64URL em canais inseguros.
- ☐ E) Ambos os termos descrevem exatamente a mesma rotina matemática, sendo indiferente a ordem de execução no microserviço de destino.

Este formulário foi criado em Unieduk. - [Entre em contato com o proprietário do formulário](#)

Este formulário parece suspeito? [Denunciar](#)

Google Formulários



